

Geheime Daten landen auf US-Servern

Angestellte laden vermehrt Informationen bei KI-Anwendungen wie Chat-GPT hoch – und verletzen damit Datenschutzrichtlinien

RETO VOGT

Ein Projektmanager eines grossen KMU hat grossen Stress: Seine Deadline läuft am nächsten Tag um 16 Uhr ab. Das ist viel zu wenig Zeit, um alle relevanten Unterlagen zu sichten. Also entscheidet er sich für eine Abkürzung: Er lädt die Dateien bei Chat-GPT hoch, wo er einen privaten Account hat. Dass die Dokumente vertraulich sind, daran denkt er nicht. Und auch nicht daran, was mit den Daten bei Chat-GPT passieren kann. Genau vor einer solchen Situation fürchtet sich Rainer Baumann. Er ist Informatikchef der Migros und sagt: «Schatten-KI macht mir Sorgen.»

Schatten-KI bezeichnet die unkontrollierte Nutzung von KI-Werkzeugen wie Chat-GPT. Wenn Mitarbeitende künstliche Intelligenz nutzen, um Sitzungsprotokolle zusammenzufassen, Kundendaten zu analysieren oder Marketingkampagnen zu entwickeln, können vertrauliche Unternehmensdaten öffentlich werden. Auch bei der Migros habe es «konkrete Fälle» dieser Art gegeben, sagt Baumann, ohne ins Detail zu gehen. Mitarbeitende hätten vertrauliche Informationen bei einer KI hochgeladen. «Niemand tat das mit böser Absicht», sagt Baumann zwar.

Doch für die Migros kann das böse enden. Die Risiken, die Baumann aufzählt, sind vielfältig: Der Abfluss von internen Daten ist das offensichtlichste Problem. Aber es drohen auch Datenschutzverletzungen und mögliche Busen, der Verstoß gegen das Urheberrecht oder der Verlust von geistigem Eigentum.

Der Fall Samsung

Der berühmteste Fall von Schatten-KI ereignete sich vor etwas mehr als zwei Jahren beim Elektronikkonzern Samsung in Südkorea. Mitarbeitende gaben interne Daten, darunter Besprechungsnotizen und Informationen zu Produktstrategien, bei Chat-GPT ein. Diese vertraulichen Informationen gelangten an die Öffentlichkeit. Denn Chat-GPT zitierte die Informationen in Antworten an andere Nutzer. Der Konzern identifizierte in dem Zusammenhang drei Fälle von schwerwiegenden Datenlecks.

Fälle wie jenen bei Samsung aufzudecken, ist aufwendig. Schwierig bis unmöglich wird es, wenn Mitarbeiter KI-Anwendungen nicht auf dem Firmencomputer nutzen, sondern beispielsweise auf dem privaten Handy. Die Wahrscheinlichkeit ist gross, dass sich in der Schweiz das wiederholt, was bei Samsung passiert ist. Insbesondere weil sich viele Mitarbeitende nicht an die internen Richtlinien halten.

Regeln statt Verbote

rev. · Unternehmen, die das Risiko der Schatten-KI im Griff haben wollen, setzen auf klare Regeln. Entscheidend sind fünf Elemente:

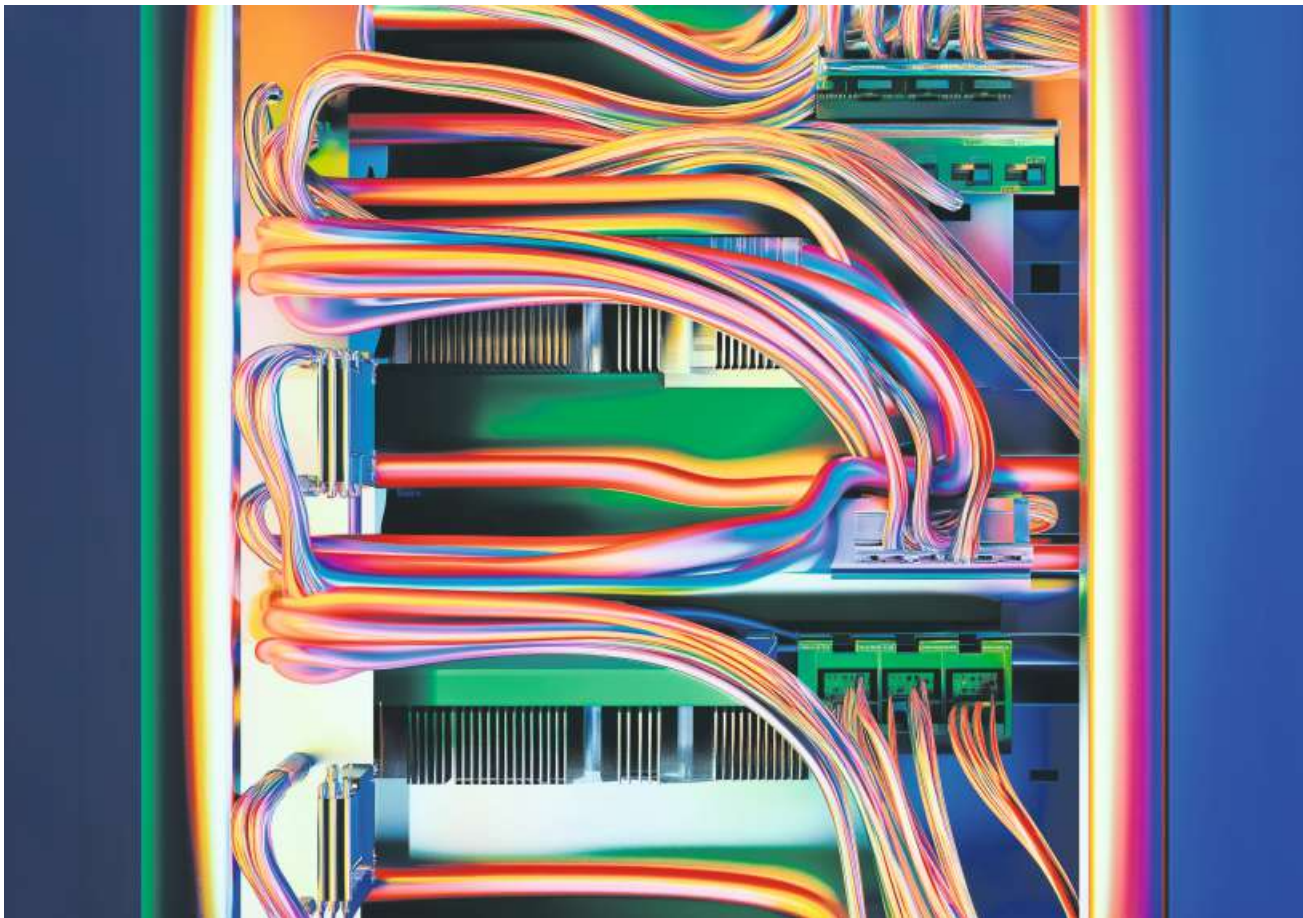
■ **Sensibilisierung:** Mitarbeiterinnen und Mitarbeiter müssen wissen, welche Risiken mit KI-Tools verbunden sind und wie Datenabflüsse entstehen.

■ **Klare Regeln:** Definieren, welche Tools erlaubt sind, welche Daten verwendet werden dürfen und wer Verantwortung trägt.

■ **Monitoring:** Technische Systeme, die KI-Zugriffe erkennen, Logdaten prüfen und Auffälligkeiten melden.

■ **Eigene Werkzeuge:** Offiziell freigegebene, interne KI-Tools anbieten. Das senkt den Reiz, externe Dienste zu nutzen.

■ **Dokumentation:** Nachvollziehbarkeit schaffen. Messen, welche Modelle wie, mit welchen Daten und Ergebnissen wie genutzt werden.



Wer bei der Arbeit schnell sein will, nutzt Chat-GPT. Doch genau das kann zum Problem werden.

ILLUSTRATION SIMON TANNER / NZZ

Das zeigen auch die Zahlen: «Sicherheitsvorfälle in Bezug auf Schatten-KI haben bei Unternehmen weltweit von 28 Prozent im Jahr 2023 auf 55 Prozent im Jahr 2025 zugenommen», sagt Thomas Holderegger, der Leiter der Security-Sparte bei der Beratungsfirma Accenture. Der Grund für die Zunahme: Interne KI-Tools werden oft zu langsam ausgerollt, externe sind hingegen frei verfügbar. Mitarbeitende wollen effizienter arbeiten und greifen deshalb zu Chat-GPT oder anderen KI-Anwendungen.

Besonders heikel ist die Situation für Banken. Sie unterstehen der Finanzmarktaufsicht (Finma) und müssen strengere Anforderungen erfüllen als andere Branchen. Der CIO (Chief Information Officer) von Raiffeisen, Niklaus Mannhart, sagt, die Herausforderung bestehe darin, den Spagat zwischen dem rasanten technologischen Fortschritt und den regulatorischen Anforderungen zu schaffen. Laut Mannhart erwartet die Finma eine angemessene Governance mit klaren Verantwortlichkeiten und eine Dokumentation des KI-Einsatzes. Deshalb erlaube die Bank auf Firmengeräten keine öffentlichen KI-Tools wie Chat-GPT. Zugelassen ist nur Copilot von Microsoft. Mannhart sagt: «Rund 6000 der 12 000 Mitarbeitenden der Raiffeisen-Gruppe nutzen das Tool mindestens einmal pro Woche – Tendenz steigend.»

Politische Interna fließen ab

In der öffentlichen Situation ist die Lage schwammiger. Die Bundeskanzlei hat 2024 Merkblätter für die Anwendung von KI-Modellen herausgegeben, seit dem Jahr 2025 besteht laut einem Sprecher eine «umfassende Strategie zum Einsatz von KI-Systemen in der Bundesverwaltung». Doch die Informatik beim Bund ist nicht zentral organisiert – «Tools oder Modelle müssen demnach auch nicht auf Stufe Bund bewilligt werden». Heisst: Jedes Departement und jedes Bundesamt schauen vor allem für sich. Entsprechend herrscht ein Wildwuchs.

Die Risiken sind jedoch dieselben wie in der Privatwirtschaft: Datenschutzverletzungen, Informationssicherheit, Compliance-Anforderungen. Dazu kommt der mögliche Verlust der digitalen Souveränität. Konkrete Vorfälle seien nicht bekannt, heisst es bei der Bundeskanzlei. Über schlimme Szenarien wolle man nicht spekulieren, schreibt ein Sprecher auf Anfrage der NZZ.

Auch die Parlamentsdienste geben den 246 Parlamentarierinnen und Par-

lamentariern wenige Leitlinien. Isabelle Chappuis, Mitte-Nationalrätin aus dem Kanton Waadt, nutzt KI beispielsweise, um sich auf Sitzungen vorzubereiten. «Wenn man bei einem Thema nicht alles versteht, kann KI helfen, um die eigenen Überlegungen zu ordnen und offene Fragen zu erkennen», sagt sie. Ebenso nutze sie KI für Übersetzungen, wenn sie beispielsweise eine Rede auf Deutsch halten müsse. DeepL werde von den Parlamentsdiensten offiziell als Tool für die Übersetzungsarbeit angeboten, sagt sie.

Andere Tools werden nicht zur Verfügung gestellt, auch Vorgaben gibt es nicht. Auf Anfrage verweisen die zuständigen Parlamentsdienste auf das Datenschutz- und das Informationssicherheitsgesetz. Entsprechend sei bei der Nutzung von öffentlicher KI die Eingabe von vertraulichen Informationen und Personendaten nicht erlaubt. «Zusätzliche Richtlinien sind momentan nicht vorgesehen und auch nicht notwendig», schreibt eine Sprecherin der Parlamentsdienste.

Doch unter der Bundeshauskuppel sehen das nicht alle so. Die Sicherheitspolitische Kommission des Nationalrats forderte diesen Sommer in einer Motion einen «sicheren KI-Assistenten für die Ratsmitglieder». Aufgrund von «erheblichem finanziellen und technischem Aufwand» beantragt das zuständige Büro des Nationalrats jedoch die Ablehnung des Vorstosses. Damit dürfte es die Motion in den Räten schwer haben. Auch die Parlamentsdienste schreiben dazu, dass der konkrete Mehrwert eines eigenen Systems nicht ausreichend ausgewiesen sei.

Verführerische Bequemlichkeit

Solange das so bleibt, nutzen Parlamentsmitglieder weiterhin externe Tools – mit erheblichen Risiken. «Wir müssen davon ausgehen, dass vertrauliche Dokumente aus dem Parlament in KI-Systemen landen», sagt der Grünen-Nationalrat und IT-Unternehmer Gerhard Andrey. Die Arbeitslast und die Bequemlichkeit der Tools verleiteten zu unsachgemäsem Einsatz. Ursache dafür sei in erster Linie, dass es für die politische Arbeit keine sichere Möglichkeit gebe, moderne Werkzeuge einzusetzen. Andrey bezeichnet die Situation im Bundeshaus als «No-Go», es brauche «zeitgemässe, unabhängige Alternativen».

Ein Kollege Andreys, der anonym bleiben will, bestätigt das. Er spricht von vertraulichen Dokumenten, die

sich seine Kolleginnen und Kollegen zur Vorbereitung von Sitzungen von Chat-GPT zusammenfassen liessen. Dass das amerikanische Unternehmen Open AI so kostenlos an interne Informationen der Schweizer Politik komme, sei den wenigsten bewusst.

Ein ähnlich verheerendes Bild zeigt sich im Gesundheitswesen. Claudio Badertscher, beim Schweizer KI-Unternehmen Alpine AI für diese Branche zuständig, sagt: «Patientendaten werden im grossen Stil bei Chat-GPT hochgeladen, vor allem, um Berichte zu erstellen.» Ärzte würden das Tool ausserdem für Übersetzungen nutzen – auch so können vertrauliche Informationen in falsche Hände geraten. In beiden Fällen handelt es sich um mögliche Verstösse gegen das Berufsgeheimnis oder die ärztliche Schweigepflicht.

Wer aber haftet, wenn durch Schatten-KI vertrauliche Daten geleakt werden? Der Zürcher Rechtsanwalt Martin Steiger sagt dazu: «Die Frage ist, wer gegenüber wem haftet.» Nach ausen, gegenüber der Kundschaft, hafte das Unternehmen. Im Innenverhältnis sei allenfalls ein Rückgriff auf verantwortliche Mitarbeiter möglich. «Ob das mit oder ohne KI geschieht, spielt letztlich keine Rolle», sagt Steiger. Der unerlaubte Einsatz von KI könne aber durchaus ein Kündigungsgrund sein.

Volle Kontrolle ist eine Illusion

Die rechtlichen Risiken sind also real. Doch wie gehen Unternehmen konkret mit dem Problem um? Das ist bisweilen schon schwer, doch einige Ansätze gibt es. Swisscom investiert etwa in die Ausbildung seiner Mitarbeitenden und blendet einen Warnhinweis ein, wenn diese Chat-GPT oder andere Sprachmodelle aufrufen. Wie die Migros setzt auch die Swisscom auf interne Chatbots, bei denen auch vertrauliche Daten verarbeitet werden dürfen.

Dass das Problem bestehen bleibt, haben auch Unternehmer erkannt. Schweizer KI-Startups wie das ETH-Spinoff Latticeflow wittern ein Geschäft: Der Markt für Lösungen, die Unternehmen im Umgang mit Regeln und Prozessen für künstliche Intelligenz helfen, soll bis 2034 über eine Milliarde Dollar schwer werden. Das sagt Petar Tsankov, Mitgründer und CEO von Latticeflow. Als neutrales, vertrauenswürdiges Land sei die Schweiz ideal positioniert, um beim Thema KI-Kontrolle weltweit Standards zu setzen, meint Tsankov.

Doch selbst wenn Unternehmen auf Lösungen von Latticeflow oder anderen setzen: Auch die beste Technik ersetzt das Verantwortungsbewusstsein nicht. Schatten-KI lässt sich nicht verbieten, nur verstehen und begrenzen. Wer das erkennt, wird nicht nur sicherer, sondern auch glaubwürdiger auftreten.

ANZEIGE

Albin Kistler

VERSTÄNDLICH
BERATEN

Wir halten Wort.